

Die Evolution der Datensicherung: Eine kritische Analyse der 3-2-1-1-0-Regel im Zeitalter von Ransomware

Autor: Mevluet Polat

Zusammenfassung

Die fortschreitende Digitalisierung und die exponentielle Zunahme von Cyber-Bedrohungen, insbesondere durch Ransomware, zwingen Unternehmen dazu, ihre Datensicherungsstrategien grundlegend zu überdenken. Das klassische 3-2-1-Paradigma der Datensicherung hat sich angesichts moderner, netzwerkübergreifender Schadsoftware als unzureichend erwiesen. Dieser Artikel analysiert die konzeptionelle und praktische Erweiterung zur 3-2-1-1-0-Regel. Anhand theoretischer Grundlagen und praxisnaher Rechenbeispiele wird dargelegt, warum diese erweiterte Methodik heute den absoluten Mindeststandard für professionelle, ransomware-resistente IT-Infrastrukturen darstellt.

1. Einleitung

In der modernen Informationsgesellschaft bilden digitale Daten das Rückgrat nahezu jeder wirtschaftlichen und institutionellen Tätigkeit. Ein Verlust dieser Daten – sei es durch technische Defekte, menschliches Versagen, Naturkatastrophen oder mutwillige Sabotage – kann für Organisationen existenzbedrohende Ausmasse annehmen. Traditionell verließen sich IT-Architekten auf die bewährte 3-2-1-Grundregel der Datensicherung. Diese besagt, dass drei Kopien der Daten auf zwei verschiedenen Medien gespeichert werden sollen, wobei eine Kopie an einem externen Standort aufbewahrt wird.

Die Schwachstelle der klassischen Methode:

Das grundlegende Problem der ursprünglichen 3-2-1-Regel liegt in der Vernetzung. Wenn alle drei Kopien netzwerkgebunden (online) sind, weist die Architektur eine kritische Schwachstelle auf. Moderne Ransomware-Gruppierungen operieren heute hochprofessionell. Die Schadsoftware infiltriert Netzwerke, breitet sich lateral (seitwärts) aus und sucht gezielt nach Backup-Servern und Speicherlaufwerken. Sind die Backup-Daten über das Netzwerk erreichbar – beispielsweise über Standardprotokolle wie SMB (Server Message Block) oder NFS (Network File System) –, kann die Ransomware potenziell sämtliche Kopien gleichzeitig verschlüsseln oder löschen. Ein prominentes Beispiel hierfür war der globale Ausbruch der Schadsoftware "NotPetya", welche komplette Unternehmensnetzwerke inklusive verbundener Backup-Speicher unbrauchbar machte.

Um diesem Umstand Rechnung zu tragen, wurde das Konzept signifikant erweitert. Die Ergänzung um eine vierte, netzwerkunabhängige Kopie (Offline oder Immutable) sowie die strikte Forderung nach einer fehlerfreien Verifikation ("Null Fehler") führte zur Etablierung der 3-2-1-1-0-Regel. Diese gilt gemäss aktuellen Best Practices der Informationssicherheit als moderne Pflicht und zwingender Mindeststandard.

2. Die fünf Elemente der 3-2-1-1-0-Regel im Detail

Die Robustheit dieses Konzepts ergibt sich nicht aus einer einzelnen Technologie, sondern aus dem Zusammenspiel der folgenden fünf detaillierten Elemente. Jedes Element adressiert einen spezifischen Vektor des potenziellen Datenverlusts.

2.1. Drei (3) Kopien

Die Regel fordert mindestens drei vollständige Datenkopien (die produktiven Originaldaten eingeschlossen). Dieses Prinzip basiert auf der statistischen Wahrscheinlichkeit von Systemausfällen. Stützt man sich auf nur ein einziges Backup (insgesamt zwei Kopien), führt ein Ausfall des Produktionssystems kombiniert mit einem gleichzeitigen Lesefehler auf dem Backup-Medium zum totalen Datenverlust. Drei Kopien stellen sicher, dass kein einzelner Fehler (Single Point of Failure) fatale Konsequenzen hat.

Beispiel aus der Praxis:

Ein Architekturbüro speichert seine laufenden CAD-Projekte auf einem Hauptserver (Kopie 1). Jeden Abend wird ein Backup auf ein separates Netzwerkspeichergerät (NAS) im Keller des Büros erstellt (Kopie 2). Zusätzlich wird ein weiteres Backup in ein externes Rechenzentrum übertragen (Kopie 3). Fällt nun der Hauptserver durch einen Hardware-Defekt aus und das NAS im Keller weist im gleichen Moment beschädigte Festplattensektoren auf, kann das Büro die Daten immer noch aus der dritten Kopie im Rechenzentrum wiederherstellen.

2.2. Zwei (2) Medientypen

Die Nutzung von zwei unterschiedlichen Speichermedien schützt vor medienspezifischen Ausfällen, Serienfehlern des Herstellers und gerätespezifischen Anfälligkeiten. Wenn beide Backups auf baugleichen Festplatten desselben Herstellers aus derselben Produktionscharge liegen, ist die Wahrscheinlichkeit hoch, dass beide Platten aufgrund eines Firmware-Fehlers oder altersbedingten Verschleisses zeitnah nacheinander ausfallen.

Beispiel aus der Praxis:

Ein Spital speichert seine Patientenakten primär auf schnellen Flash-Speichern (SSDs) für den rasanten Zugriff durch die Ärzte. Das erste Backup erfolgt auf klassische, magnetische Festplatten (HDDs). Das zweite Backup wird auf Magnetbänder (LTO-Tape) geschrieben. Tritt

nun ein Softwarefehler im Speicher-Controller auf, der gezielt das Dateisystem von Festplatten zerstört, bleiben die Daten auf den Magnetbändern unangetastet, da diese eine völlig andere physikalische Speichermethode und Zugriffslogik aufweisen.

2.3. Ein (1) externer Standort (Offsite)

Lokale Ereignisse können ganze Gebäude oder Standorte in Mitleidenschaft ziehen. Eine Kopie muss daher zwingend geografisch getrennt gelagert werden. Dies schützt vor Elementarschäden (Feuer, Wasser, Erdbeben) sowie vor Diebstahl oder Vandalismus.

Beispiel aus der Praxis:

Im März 2021 brannte ein grosses Rechenzentrum eines namhaften Cloud-Anbieters in Strassburg komplett nieder. Unternehmen, die ihre Daten ausschliesslich in diesem einen Rechenzentrum (inklusive der Backups auf Servern im selben Raum) gespeichert hatten, erlitten einen Totalverlust. Ein Unternehmen, das die 3-2-1-1-0-Regel befolgte, hatte seine Daten beispielsweise primär in Zürich, eine Kopie in Bern und die externe Offsite-Kopie in einem Bunker in den Schweizer Alpen gespeichert. Der Brand in einem Rechenzentrum hätte hier lediglich zu einer vorübergehenden Umschaltung auf den externen Standort geführt.

2.4. Eine (1) Offline-Kopie oder unveränderliche Sicherung (Immutable)

Dieses Element (die erste "1" in der Erweiterung) ist die direkteste Antwort auf die Ransomware-Epidemie. Mindestens eine Kopie muss vollständig vom Netzwerk getrennt (Air-Gapped) oder durch spezielle Software-Mechanismen unveränderlich (Immutable) gespeichert sein. Eine Offline-Kopie kann per Definition nicht von Schadsoftware verschlüsselt werden, da schlichtweg keine physische oder logische Verbindung zum infizierten Netzwerk existiert. Unveränderliche Backups (WORM – Write Once, Read Many) erlauben das Schreiben der Daten, verhindern aber für einen vordefinierten Zeitraum das Löschen oder Ändern dieser Daten – selbst durch Systemadministratoren.

Beispiel aus der Praxis:

Ein Finanzinstitut wird Opfer eines Cyber-Angriffs. Die Hacker erbeuten Administrator-Passwörter und verschlüsseln alle produktiven Server sowie das netzwerkangebundene Backup-NAS, um Lösegeld zu erpressen. Das Institut verfügt jedoch über ein LTO-Bandlaufwerk. Jeden Freitagabend entnimmt ein Mitarbeiter das Magnetband aus dem Laufwerk und schliesst es in einen feuerfesten Tresor ein (Offline-Kopie). Da das Band im Tresor keine Netzwerkverbindung hat, konnten die Hacker es nicht verschlüsseln. Das Institut kann die Systeme bereinigen und die Daten vom Band aus dem Tresor wiederherstellen, ohne Lösegeld zahlen zu müssen. Alternativ nutzt das Institut einen "S3 Object Lock" in der Cloud, welcher technisch verhindert, dass Backup-Dateien vor Ablauf von 30 Tagen gelöscht oder überschrieben werden können (unveränderliche Sicherung).

2.5. Null (0) Fehler

Die letzte Ziffer, die Null, steht für null Fehler bei der Verifikation. Ein Backup ist im Ernstfall absolut wertlos, wenn es sich nicht wiederherstellen lässt. Historisch betrachtet blieben defekte Backups oft wochenlang unbemerkt, da nur die Bestätigung "Backup erfolgreich" geprüft wurde, nicht jedoch die tatsächliche Lesbarkeit der Daten. Alle Backups müssen automatisch auf Fehlerfreiheit verifiziert werden. Kein Backup gilt ohne erfolgreiche Verifikation als gültiges Backup.

Beispiel aus der Praxis:

Moderne Backup-Software bietet Funktionen, die als automatische Integritätsprüfung oder "SureBackup" bekannt sind. Nach dem nächtlichen Backup-Job startet die Software das Backup in einer isolierten, virtuellen Umgebung (Sandbox). Das System fährt den gesicherten Server virtuell hoch, prüft, ob das Betriebssystem startet (Heartbeat), testet, ob die Datenbank auf Anfragen reagiert, und scannt die Daten auf versteckte Malware. Erst wenn all diese Tests erfolgreich absolviert wurden und das System wieder heruntergefahren ist, meldet die Software: "0 Fehler – Backup erfolgreich verifiziert". Schlägt der Test fehl, wird der Administrator sofort alarmiert, bevor ein echter Datenverlust eintritt.

3. Umsetzung in der Praxis: Architektur einer modernen Datensicherung

Die theoretischen Konzepte erfordern eine systematische und durchdachte Implementierung in die bestehende IT-Infrastruktur. Die Umsetzung der 3-2-1-1-0-Regel lässt sich in verschiedene Schichten (Tiers) unterteilen, die von rasanter Verfügbarkeit bis hin zu langfristiger Archivierung reichen.

Kopie 1 – Lokal (Der Performance-Tier)

Die erste Kopie dient der schnellen täglichen Wiederherstellung. In der Praxis kommt es häufig vor, dass ein Anwender versehentlich eine Datei löscht oder ein Server nach einem Update nicht mehr startet. Hier ist Geschwindigkeit gefragt (niedrige Recovery Time Objective - RTO). Diese Kopie wird als schnelles Disk-Backup auf einem lokalen NAS oder einem speziellen Deduplizierungsspeicher abgelegt. Der Zugriff erfolgt nahezu in Echtzeit über das lokale Hochgeschwindigkeitsnetzwerk (LAN).

Kopie 2 – Sekundär (Der Redundanz-Tier)

Die zweite Kopie befindet sich idealerweise auf einem anderen Medientyp oder einem separaten Storage-System, kann sich aber am gleichen oder an einem sehr nahen Standort befinden (z.B. in einem anderen Brandabschnitt des Firmengebäudes). Oftmals werden hier

leicht günstigere, hochkapazitive Speichersysteme eingesetzt. Diese Kopie sichert die sofortige Verfügbarkeit ab, falls das primäre NAS-System der Kopie 1 einen Hardware-Defekt erleidet.

Kopie 3 – Offsite (Der Disaster-Recovery-Tier)

Um gegen standortweite Katastrophen gerüstet zu sein, wird die dritte Kopie ausgelagert. Für Schweizer Unternehmen bietet sich hier die Replikation in ein Schweizer Cloud-Rechenzentrum an (um die strengen Datenschutzgesetze gemäss DSG/FADP einzuhalten). Alternativ kann ein zweiter, geografisch getrennter Unternehmensstandort genutzt werden (z.B. Replikation der Daten vom Hauptsitz in Zürich in eine Niederlassung in Genf).

Kopie 4 – Offline (Der Air-Gap-Tier)

Dieser Schritt implementiert den entscheidenden Schutz gegen Ransomware. Dies geschieht in der Regel durch ein klassisches Tape-Laufwerk (Magnetband) oder rotierende Wechselmedien (externe Festplatten). Das entscheidende Kriterium ist die **physische Trennung**. Nach Abschluss des Backup-Jobs wirft das System das Medium aus. Ein Mitarbeiter oder ein Roboterarm (in einer Tape-Library) entnimmt das Medium, wodurch es physisch vom Stromnetz und Datennetz getrennt ist. Es wird offline und sicher (z.B. in einem Tresor oder bei einem spezialisierten Kurierdienst) aufbewahrt.

Null Fehler – Die lückenlose Verifikation

Die praktische Umsetzung erfordert die Abkehr vom manuellen Testen, da dies in grossen Umgebungen personell nicht leistbar ist. Es werden Skripte und automatisierte Jobs eingerichtet. Jeder Backup-Job generiert Prüfsummen (Checksums), die beim Lesevorgang verglichen werden. Zudem werden regelmässige Restore-Tests simuliert, deren Ergebnisse in detaillierten Compliance-Reports an die Geschäftsleitung oder den IT-Sicherheitsbeauftragten (CISO) gemeldet werden.

4. Rechenbeispiel zur Umsetzung: Kapazitätsplanung für ein KMU

Die theoretische Planung einer Datensicherungsarchitektur erfordert ein exaktes mathematisches Verständnis des Speicherbedarfs. Daten wachsen kontinuierlich, und Backup-Historien (Retentionen) multiplizieren diesen Bedarf enorm. Das folgende Rechenbeispiel veranschaulicht die Dimensionen für ein typisches kleines bis mittleres Unternehmen (KMU).

Die Ausgangslage (Parameter):

- **Produktionsdaten:** Das KMU sichert täglich 2 Terabyte (TB) an aktiven Produktionsdaten (Datenbanken, E-Mails, Dateiserver).

- **Retentionzeit (Aufbewahrungsfrist):** Die Daten sollen für 30 Tage rückwirkend im schnellen Zugriff verfügbar sein.
- **Änderungsrate (Change Rate):** Täglich verändern sich etwa 10 Prozent der Daten (neue Dateien, geänderte Dokumente, neue Datenbankeinträge).

Um Speicherplatz zu sparen, wird in der Praxis selten jeden Tag ein komplettes (Full) Backup von 2 TB erstellt. Stattdessen wird am ersten Tag ein Vollbackup gemacht, und an den folgenden Tagen werden nur die Daten gesichert, die sich seit dem letzten Backup geändert haben (Inkrementelles Backup).

Berechnung Kopie 1 (Lokal):

- Das initiale Vollbackup benötigt: **2 TB**.
- Die tägliche Änderungsrate beträgt 10 % von 2 TB, was **200 GB** pro Tag entspricht.
- Bei einer Aufbewahrung von 30 Tagen haben wir 1 Vollbackup und 29 Inkremente.
- Berechnung der Inkremente: 29 Tage $\times$ 200 GB = 5.800 GB = **5,8 TB**.
- **Gesamter Rohkapazitätsbedarf lokal:** 2 TB (Voll) + 5,8 TB (Inkremente) = **7,8 TB** auf dem lokalen NAS-System.

Erklärung: Das lokale NAS muss zwingend über mindestens 7,8 TB nutzbaren Speicherplatz verfügen, zuzüglich eines Puffers (Overhead) für Dateisystemoperationen, womit man in der Praxis eher ein 10 TB oder 12 TB System dimensionieren würde.

Berechnung Kopie 2 (Sekundär):

Da diese Kopie eine identische Vorhaltezeit (30 Tage) aufweist und die gleiche Datenmenge vorhält, ergibt sich hier ebenfalls ein Bedarf von weiteren **7,8 TB** auf einem zweiten Medium (z.B. einem kostengünstigeren Speicher am gleichen Standort).

Berechnung Kopie 3 (Offsite in der Cloud):

Die Übertragung von 7,8 TB über eine normale Internetleitung kann lange dauern und hohe Speicher- und Bandbreitenkosten verursachen. Daher kommen hier intelligente Algorithmen zur Datenreduktion zum Einsatz. Die Deduplizierung analysiert die Datenblöcke und speichert identische Blöcke nur ein einziges Mal. Zudem werden die Daten vor der Übertragung komprimiert.

- Die replizierte Datenmenge geht in eine Schweizer Cloud.
- Angenommen wird eine branchenübliche Deduplizierungs- und Kompressionsrate von 3:1.
- Berechnung: 7,8 TB Rohdaten / 3 = **effektiv rund 2,6 TB Cloud-Kapazität**.

Erklärung: Das Unternehmen muss beim Cloud-Anbieter somit nicht knapp 8 TB, sondern lediglich 2,6 TB Speicherplatz abonnieren, was die laufenden Betriebskosten (OPEX) drastisch senkt, während die Sicherheit durch die Georedundanz massiv erhöht wird.

Berechnung Kopie 4 (Offline-Tape):

Für die langfristige und vom Netzwerk getrennte Aufbewahrung wird oft auf das GFS-Prinzip (Grandfather-Father-Son) zurückgegriffen. Im Rahmen dieses Beispiels wird eine vereinfachte Methode angewendet: ein wöchentliches Vollbackup. Inkremente auf Bändern sind bei der Wiederherstellung unpraktisch, da man im Notfall mehrere Bänder nacheinander einlesen müsste.

- Es wird jede Woche ein vollständiges Backup (2 TB) auf ein Magnetband geschrieben.
- Um einen Monat (ca. 4 Wochen) offline abzudecken, werden vier Bänder benötigt.
- Berechnung: 4 Tapes × 2 TB pro Vollbackup = **8 TB Tape-Kapazität**.

Erklärung: Der IT-Administrator benötigt einen rotierenden Pool von mindestens vier LTO-Bändern. Jedes Band fasst ein komplettes Abbild der Unternehmensdaten zum Zeitpunkt der Sicherung. Nach dem Schreiben wird das Band physisch entfernt, womit das Air-Gap-Konzept gegen Ransomware erfüllt ist.

5. Fazit

Die Anpassung der IT-Sicherheitsstrategien an die dynamische und hochgradig professionalisierte Bedrohungslandschaft ist keine Option, sondern eine unternehmerische Notwendigkeit. Die Erweiterung der klassischen 3-2-1-Regel zur 3-2-1-1-0-Methodik spiegelt die Erkenntnis wider, dass bloße Datenredundanz nicht mehr ausreicht, wenn das gesamte Netzwerk als potenzielle Angriffsfläche (Attack Surface) betrachtet werden muss.

Durch die zwingende Integration einer offline gelagerten oder unveränderlichen Kopie wird Ransomware-Akteuren der Hebel zur Erpressung entzogen. Gleichzeitig wandelt die absolute Fehlerintoleranz («Null Fehler»-Verifikation) den Datensicherungsprozess von einem passiven «Fire-and-Forget»-Ablauf in eine proaktive, verifizierte und verlässliche Versicherungs-Police für die digitalen Kernwerte eines Unternehmens. Die mathematisch fundierte Dimensionierung der Speicherarchitekturen – unter Berücksichtigung von Änderungsraten und Deduplizierungseffekten – garantiert dabei eine wirtschaftlich tragbare und zugleich hochsichere Umsetzung in der Praxis. Organisationen, die diese Mindeststandards heute noch ignorieren, handeln fahrlässig und riskieren im Falle einer Cyber-Attacke nicht nur erhebliche finanzielle Schäden, sondern potenziell das Fortbestehen des gesamten Unternehmens.